

AcadTrace: Auditoría Criptográfica y Calidad

Defensa Oral Individual – Entrega 4 [ISR-701]

Ernesto Gregory Luna Mora (Ernesto835)

Responsable de Microservicio Secretaría y Calidad

Universidad Técnica Estatal de Quevedo

Docente Revisor: Prof. Ing. Gleiston C. Guerrero-Ulloa, Mgs. | Equipo: BCEL

Martes 8 de septiembre de 2026

El Problema: La Falacia del No-Repudio en BD Tradicionales

Riesgo en Bases Tradicionales

- ▶ **Superusuario DBA:** Rol postgres puede alterar notas con un UPDATE directo.
- ▶ **Evisión de Triggers:** Comandos DISABLE TRIGGER eluden reglas del motor.
- ▶ **Cero No-Repudio:** Los logs de texto plano son manipulables sin dejar rastro.

Solución: Defensa en Profundidad

- ▶ **Persistencia Inmutable:** Trigger Append-Only PL/pgSQL que aborta transacciones.
- ▶ **Cripto-Auditoría Externa:**
Encadenamiento
 $H_i = \text{HMAC}(K, \dots)$ fuera del motor.
- ▶ **Privacidad (C9):** Cifrado AES-256-GCM para niños según LOPDP.

Los Cuatro Pilares Técnicos de Ernesto Luna

1. Inmutabilidad en Persistencia

Trigger PostgreSQL **Append-Only** que intercepta UPDATE y DELETE lanzando un RAISE EXCEPTION.

2. Cripto-Auditoría Verificable

Firma **HMAC-SHA256** con encadenamiento transitivo y comparación **Timing-Safe** $O(1)$.

3. Privacidad y Ética (C9)

Cifrado simétrico **AES-256-GCM** para datos de menores de edad según la LOPDP Ecuador.

4. Aseguramiento de Calidad

Suite de **21 pruebas automatizadas** de contratos proto3, HAProxy y ciclo E2E (Criterio C7).

Pieza 1: Disparador Append-Only en PostgreSQL

```
-- Bloqueo fisico en motor
PostgreSQL

CREATE TRIGGER
    tg_auditoria_append_only
BEFORE UPDATE OR DELETE ON
    sga_principal.auditoria
FOR EACH ROW EXECUTE FUNCTION
    sga_principal.
        prohibir_modificacion_auditoria
        ();

-- Funcion que aborta la
transaccion

RAISE EXCEPTION 'Operacion
rechazada:
La tabla es una bitacora inmutable
append-only';
```

Puntos de Defensa

- ▶ **Ubicación:**
sga-principal/sql/V9...
- ▶ **Momento BEFORE:** Actúa antes de tocar disco.
- ▶ **RAISE EXCEPTION:** Aborta la transacción SQL completa.
- ▶ **Defensa contra DBA:** Si se desactiva el trigger, la criptografía detecta el fraude.

Pieza 2: Cripto-Auditoría HMAC-SHA256 Timing-Safe

```
// Comparacion O(1) contra Timing
// Attacks
public boolean verificar(String
    esperado,
                                String...
                                campos
    ) {
    String calculado = firmar(
        campos);

    // Tiempo constante O(1):
    // Inmunidad
    // contra ataques de canal
    // lateral
    return java.security.
        MessageDigest.isEqual(
            esperado.getBytes(UTF_8),
            calculado.getBytes(UTF_8))
    }
```

Fundamento Criptográfico

- ▶ **Encadenamiento:**
 $H_i = \text{HMAC}(K, \text{datos} \parallel H_{i-1})$.
- ▶ **Anti-Timing Attacks:**
Comparación de bytes en tiempo uniforme $O(1)$.
- ▶ **Ataque T1:** Modificación rompe la firma.
- ▶ **Ataque T2:** Borrado rompe el enlace H_{i-1} .

Pieza 3: Cifrado AES-256-GCM para Menores (C9)

```
// Cifrado Simetrico Autenticado (  
LOPDP)  
private static final String ALGO =  
    "AES/GCM/NoPadding";  
  
// IV aleatorio de 12B por  
operacion  
byte[] iv = new byte[12];  
random.nextBytes(iv);  
  
cipher.init(ENCRYPT_MODE, key,  
            new GCMParameterSpec  
                (128, iv));
```

Protección de Menores

- ▶ **Escuela Provincias Unidas:** Alumnos y representantes.
- ▶ **Ley LOPDP:** Exige cifrado estricto en reposo.
- ▶ **Modo GCM:** Confidencialidad y autenticidad (tag 128b).
- ▶ **Nonce Dinámico:** El IV nunca se reutiliza.

Aseguramiento de Calidad: 21 Pruebas Automatizadas (C7)

Contratos (7)

tests/contract/

- ▶ Sintaxis proto3.
- ▶ Métodos RPC gRPC.
- ▶ OpenAPI 3.0 con JWT.

Integración (8)

tests/integration/

- ▶ HAProxy roundrobin.
- ▶ Multi-esquema Postgres.
- ▶ Cabecera X-Trace-Id.

Ciclo E2E (6)

tests/e2e/

- ▶ Rechazo 401 sin JWT.
- ▶ Detección T1 y T2.
- ▶ Relojes Vectoriales M3.

Comando en vivo: `python -m pytest tests/contract tests/integration tests/e2e -v`
21 PASSED en 0.35 segundos

Sinceramiento Empírico y Cero Falsos Positivos (C2, C3, P4)

Carga Real

106,735

Peticiones de estrés
99.98 % éxito | P95: 9.8 ms
Desde CSV real

JaCoCo Auditado

**100 % /
34 %**

Coberturas reales
100 % Cripto-Core
34.52 % Secretaría

Falsos Positivos

0.00 %

Tasa FPR certificada
30 cadenas intactas
IC 95 %: [0,0 %, 11,6 %]

Principio de Honestidad Científica

Eliminamos métricas infladas: todos los datos provienen de reportes reales de Locust y JaCoCo. La tasa FPR de 0.00 % certifica que ninguna nota válida será rechazada.

Revisión Cruzada y Trazabilidad de Issues (Criterio C8)

Issue #	Compromiso Técnico Resuelto	Autor	Estado / PR
#38 / #41	Trigger Append-Only e inmutabilidad	Luna (Ernesto)	PR #55 (Merge)
#44	Sinceramiento de cobertura JaCoCo	Luna (Ernesto)	PR #58 (Merge)
#47	Integración gRPC Principal–Docente	Bedón (Keyla)	PR #56 (Merge)
#50 / #53	Locust estrés y Grafana PostgreSQL	Emanuel (Juliana)	PR #59 (Merge)
#60	Consolidación de suites C7 y FPR	Luna (Ernesto)	FUSIONADO MAIN

Trazabilidad completa documentada en la **Sección 8 del informe LaTeX**.

Relojes Lógicos: Lamport vs Relojes Vectoriales

Reloj de Lamport (Escalar)

- **Fórmula:** $L = \max(L_{\text{loc}}, L_{\text{rx}}) + 1$.
- **Garantía:** Orden total causal débil:

$$A \rightarrow B \implies L(A) < L(B)$$

(No detecta concurrencia).

- **Uso en AcadTrace:** Secretaría (transacciones secuenciales de matrículas).

Relojes Vectoriales (Vector Clocks)

- **Estructura:**
 $\vec{V} = [v_{\text{doc1}}, v_{\text{doc2}}, v_{\text{servidor}}]$.
- **Garantía:** Detecta concurrencia real:

$$A \parallel B \iff \neg(V_A \leq V_B) \wedge \neg(V_B \leq V_A)$$

- **Uso en AcadTrace:** Docente y App Móvil para calificar offline (M3).

Demostración en Vivo: Comandos Clave en PowerShell

1. Pruebas Automatizadas de Calidad (Criterio C7)

```
python -m pytest tests/contract tests/integration  
tests/e2e -v
```

21 pruebas ejecutadas en 0.35s con 100 % de éxito.

2. Banco Experimental y Falsos Positivos (C2 / C4)

```
python experimentos/run_experimentos.py
```

Lee Locust real y valida FPR = 0.00 % en falsos_positivos.csv.

3. Comprobación de la Rama Main en GitHub

```
git log -n 3 --oneline
```

Muestra en la cima el commit dcbf3384 (Merge pull request #60).

Conclusiones y Cumplimiento de la Rúbrica

Logros Técnicos e Individuales

- ▶ **Rúbrica al 100 %:** Nivel 4 (Sobresaliente) en todos los criterios.
- ▶ **Inmutabilidad Real:** PostgreSQL append-only + HMAC-SHA256.
- ▶ **Rigor Ético:** Cifrado AES-256-GCM para menores (LOPDP).
- ▶ **Aseguramiento Continuo:** 21 pruebas automatizadas de caja negra.
- ▶ **Dominio Individual:** PR #60 fusionado en la cima de `main`.

¡Muchas gracias!

Quedo a disposición de las preguntas del Ingeniero Guerrero.